

arise for containers, when technically possible and supported by a risk assessment, separation and isolation could be obtained for containers similarly to virtual machines

- The [Knowledge Base article 5021566](#) (Guidance and Best Practices for Cryptography) has been refreshed with latest guidance and best practices. This article is referred to in the controls 2.1, 2.4, 2.5A and 2.6 and will be further updated according to Swift Post Quantum strategy
- Control 2.3 System Hardening explicitly refers to Windows Management Instrumentation (WMI) and PowerShell as examples of native OS feature to be considered when shielding a Windows system
- Control 2.9 Transaction Business Controls identifies Swift Universal Confirmation (UC), when available, as an option to perform validation or reconciliation aside to MT 900/MT 910 and MT 940/MT 950
- Reference to the optional Luna Backup device as a removable equipment for proper management as per control 3.1 Physical Security and 5.4 Password Repository Protection
- Alliance Left and Right Security Officer (LSO/RSO) accounts are specifically named as privileged accounts in the Glossary of terms. Control 4.2 Multi Factor Authentication is expected to be in place on those accounts as per the control 2.10 Application Hardening and as explicitly mentioned in the related Alliance Security Guidance. However, sometimes considered as unused break-glass accounts (individual accounts are indeed assigned for accountability), generic guidance is provided regarding proper usage of break-glass accounts in control 1.2 OS Privileged Account Control and control 2.10 Application Hardening
- Control 4.2 requires Multi-Factor Authentication on one authentication stage/step for external privileged access to manage Firewalls
- The reference to SwiftNet Online Operations Manager (O2M), not on swift.com but through a Web Access service, has been corrected in control 5.1 Logical Access Control and 5.4 Password Repository Protection. The Secure Channel service, available to SwiftNet security officers through swift.com, is similarly referred to
- Control 6.1 Malware Protection advises to protect, when technically possible, non-Windows systems located within a secure zone or hosting a customer client connector
- Control 6.2 Software Integrity includes third-party and in-house developed software deployed as per the Change and Release Management
- There are, at the publication time of this version, no specific guidance or expectations regarding the usage of AI-based tools to support the CSP controls. The same level of care must be granted to any tool introduced and used within the institution, for what regards the confidentiality, integrity, and availability of the data processed. However, control 7.2 Security Training and Awareness is updated with a reference to Deepfake as an example of AI-based threats
- Control 7.3A Penetration Testing incorporates some guidelines based on the community experience
- The section Scope of Security Controls and the Appendix D Glossary of Terms clarify the notion of bridging servers, back-office first hops, customer client connectors and the new Alliance Connect options
- Several drawings have been refreshed or added in the section Architecture Types, the Appendix B Secure Zone Reference Architecture' and the Appendix G Back-Office First Hop Flows Protection to visualise the new Alliance Connect Virtual on Premises VPNs
- Appendix F has been updated, for instance, Alliance Access Integration Platform (IPLA) and Swift Integration Layer (SIL) are expected to reach their end of life in 2026 but remain in-scope till then, and cleaned off some obsolete elements

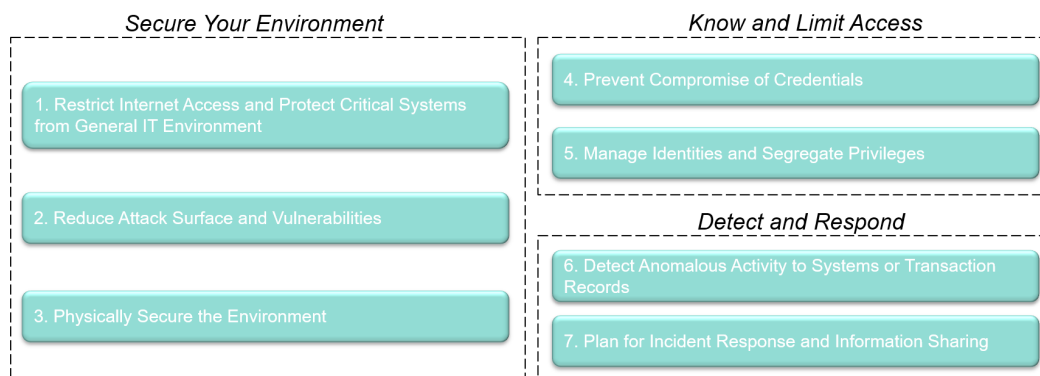
Swift recommends users to consult the CSCF v2026 compared to v2025 version of this document to view full details of changes. This file does not include editorial changes that Swift performs to improve the readability of the document.

# Framework Objectives and Principles

## Objectives and Principles



The security controls are based on three overarching framework objectives, supported by seven security principles. Objectives are the highest level structure for security within the user's environment. The associated principles elaborate on the highest priority focus areas within each objective. The objectives and corresponding principles include the following:



**Drawing 1: Framework Objectives and Principles**

The 32 security controls (26 mandatory controls and 6 advisory controls) detailed in this document underpin these objectives and principles where the first two principles, sharing common controls, have been grouped. The controls help mitigate specific cyber-security risks that Swift users face due to the cyber-threat landscape. Within each security control, Swift has documented the most common risk drivers that the control is designed to help mitigate. Addressing these risks aims to prevent or minimise undesirable and potentially fraudulent business consequences, such as the following:

- unauthorised sending or modification of business transactions
- processing of altered or unauthorised Swift inbound transactions (that is, received transactions)
- business conducted with an unauthorised counterparty
- confidentiality breach (of business data, computer systems, or operator details)

- integrity breach (of business data, computer systems, or operator details).

Ultimately, these consequences represent enterprise-level risks, including the following:

- Financial Risk
- Legal Risk
- Regulatory Risk
- Reputational Risk.

### Integration with Security Governance and Risk Management

Swift encourages users to consider cyber risk management in the broadest possible terms, including beyond the scope of the user's Swift infrastructure and the Swift security controls. For the most effective management of risk, users should not view the implementation of these security controls as a one-time activity, nor as exhaustive or all-inclusive. Users should, instead, incorporate Swift's controls into an ongoing cyber-security governance and risk programme within their organisation, considering sound judgement and the latest best practices, taking into account user-specific infrastructure and configurations. As a result, **users can re-use and benefit from existing policies, procedures, and controls that have been established to manage other areas of cyber risk.** To help users in this approach, **Appendix E** contains a link to the mapping of the Swift security controls against different international security standard frameworks: **NIST Cybersecurity Framework** (v1.1 and later, v2.0), **ISO 27002 (2022)**, **PCI-DSS 4.0**, **SOC2 TSC 2017** and the **United Compliance Framework**. Swift has also published a [Getting Started Guide](#) to assist users in assessing counterparty cyber-security risk and incorporating this into the risk management framework.

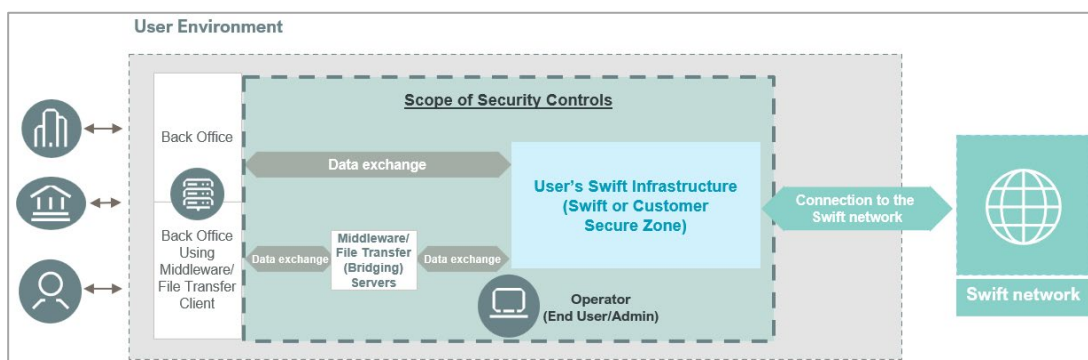
There are, at the publication time of this version, no specific guidance or expectations regarding the usage of AI-based tools to support the CSP controls. The same level of care must be granted to any tool introduced and used within the institution, for what regards the confidentiality, integrity, and availability of the data processed.

A holistic approach to cyber risk is most effective in avoiding enterprise-level risk, therefore improving the overall safety of each individual organisation and the wider financial community.

Additionally, users should have the correct level of accountability and oversight for their cyber risk management activities. Generally, a Chief Information Security Officer plays a prominent role in this domain by directing the priorities of the security programme and soliciting the appropriate support and guidance from the Board.

# Scope of Security Controls

The scope of security controls in this document encompasses a defined set of components in the user's environment (see Drawing 2).



Drawing 2a: Scope of Security Controls

A) The security controls apply to the following **in-scope components**:

- **User's Swift infrastructure** – The collection of – on-premises or remote (that is hosted or operated by a third party, or both), - Swift-specific components managed by or for users, including applications, authentication services, network devices, tokens and other removable media or equipment, and supporting hardware. Examples of user's Swift infrastructure set-up and so-called Swift-related components (depending on the user [architecture type](#)) are as follows:
  - **Swift Secure Zone**: a segmented zone that separates Swift-related systems from the wider enterprise environment (further detailed in control 1.1). Its primary purpose is to contain and protect the Swift footprints as identified below. This zone can expand beyond the user's Swift infrastructure and can contain non-Swift related systems provided those non-Swift related systems are protected similarly to Swift-related systems.
  - **Messaging interface**: a software that supports the use of MT, MX, or ISO 20022 message standards through Swift FIN, InterAct, FileAct, and SwiftNet Instant messaging services. The software provides the means for users to connect these business applications to Swift messaging services and is typically connected directly to the communication interface (the [decision tree](#) can also be used to identify the intricate cases of components connecting to the communication interface). Swift provides messaging interfaces (for example, Alliance Access, Standalone Alliance Access, Alliance Messaging Hub or Alliance Messaging Hub Instant). Messaging interfaces that hold a Swift-compatible label can also be provided by third-party vendors. A messaging interface is considered as a Swift footprint.
  - **Communication interface**: a software that provides a link between the SwiftNet network and usually the messaging interface software or a back-office system. Communication interfaces provide centralised, automated, and high-throughput integrations with different in-house financial applications and service-specific interfaces. Swift provides the communication interfaces (for example, Alliance Gateway or Alliance Gateway Instant). Communication interfaces that hold a Swift-compatible label can also be provided by third-party vendors. A communication interface is considered as a Swift footprint. While Alliance Gateway is usually linked with a messaging interface, Alliance Gateway Instant is usually directly linked with a back-office system (unless an explicit messaging interface is also integrated in the user infrastructure).
  - **SwiftNet Link (SNL)**: SNL is a mandatory software product for access to FIN, InterAct, and FileAct messaging services over a secure IP network. This document refers to the SNL, a Swift footprint, as part of the communication interface scope.

- **Connector:** Connectors are local software designed to facilitate communication with an external messaging interface or a communication interface (or both), to a Swift connectivity provider (handling as such the external connection) or an outsourcing agent. When using a connector, interface components are usually offered by a Swift connectivity provider, a remote Group Hub<sup>1</sup> or Swift).

**Swift connector** is a connector specifically designed to support Swift business. It is usually provided by Swift (for example, Alliance Cloud SIL, Direct Link, Alliance Lite2 AutoClient, in combination or not with SIL, or Swift Microgateway). Swift connector, holding a Swift-compatible label, can also be provided by third-party vendors. A Swift connector is considered as a Swift footprint.

**Customer connector** is typically a commercial off-the-shelf product configured for Swift purposes. It includes generic file transfer solutions or local middleware systems implementations (such as IBM® MQ server, Apache Kafka or Solace server/broker) used to facilitate an external connection with Swift-related components shared by a Swift connectivity provider, a remote Group Hub or an outsourcing agent. Those generic elements not provided by Swift (or not labelled as Swift-compatible) are considered as a non-Swift footprint.

An application developed in-house that implements and consumes Swift APIs (basically by either using the specifications or integrating the Swift SDK) to connect and transmit business transactions independently<sup>2</sup> to Swift messaging services<sup>3</sup> exposed by the Swift API Gateway, is also considered as a customer (bespoke API) connector or a non-Swift footprint (also referred to as a 'Swift Zero footprint' since it indeed does not hold any Swift footprint; however it still has a footprint: a customer bespoke API connector).

To protect the flows between users and Swift and to align expectations throughout the community, all the user's endpoints (application or footprint residing on a system) will be considered as a customer connector, irrespective of the nature of the endpoint (either a server or a client). While the servers are already fully in scope, the '**customer client connectors**' (such as an endpoint consuming APIs, a middleware or a file transfer client) used to connect to a Swift connectivity provider, an outsourcing agent or a remote Group Hub, was first introduced as an advisory component in-scope. Such 'customer client connector' is to be considered as mandatory in scope of several controls of the CSCF v2026. As from now, the concept of customer connector will gradually cover both a server or a client endpoint connecting to a Service Provider or to Swift. The term 'customer (client) connector' is sometimes also used to cover all the types of customer connectors (that is server and client).

The 'customer facing' webserver operated by Swift WebAccess service providers are also considered as customer connectors.

When used alone, the term **connector** refers to both Swift connectors and customer connectors.

- **Customer Secure Zone:** a secure operational (sometime called production) environment that separates non-Swift footprint, such as the customer connector, from the wider enterprise environment (further detailed in control 1.5). Its primary purpose is to contain and protect the customer connector. This zone can contain non-Swift related systems provided those non-Swift related systems are protected similarly to Swift-related systems. ***Users already having a Swift secure zone may consider adding in that zone a customer connector (in which case there is no need to create a specific customer secure zone for it).*** Note: a customer

<sup>1</sup> A remote Group Hub is accessed through externally exposed connections (that means, not through a wide area network - WAN or extended virtual local area network - VLAN). See the [Knowledge Base article 6000598](#) for additional information

<sup>2</sup> Independently means without using a communication interface or a Swift connector such as SIL, Direct Link or Swift Microgateway

<sup>3</sup> Business transactions to messaging services refers to requests introducing or affecting Swift payments (such as creation of MT 101, MT 103, MT 202, MT 205, their MX equivalent, pain.001, pacs.008, pacs.009, or cancelling/stopping/recalling/modifying those requests) or instructions that lead to a payment. On the other side, queries on previous transactions (such as through the Basic Tracker), pre-validation, conversion or screening performed before submitting business transactions are not considered affecting messaging services (being ancillary services) and can be considered as out of scope unless they require the same roles/entitlements as business transactions to messaging services (no separation of duties and precautionary principle has to be applied). See the last bullet of this section

secure zone can also contain systems supporting an existing Swift secure zone such as a storage area network (SAN), a hosted database, a virtualisation platform, authentication services or middleware servers.

**Secure zone:** refers to a Swift or a customer secure zone.

- **Swift Hardware Security Modules (HSMs)**, connected and disconnected personal tokens, and smart cards.

A **new HSM** model (the PED-less Luna SA7) is available and is progressively replacing the current HSM model (the Luna IS6). While the same level of security is maintained with this replacement, the new HSM is, due to its PED-less nature, identified as in scope of all relevant controls. As such:

- The term “**HSM**”, refers to both existing (Luna IS6) and new (Luna SA7) models –no change.
- The term “**New HSM**” is used when newly identified as in scope component of several controls to facilitate the transition. Consequently, those controls need to be formally considered when installing, using the new HSM model (Luna SA7 as per documentation) and further assessing compliance with those controls.
- At the end of the HSM migration, the term “new” in “new HSM” will disappear and “HSM” will remain.
- Firewalls, switches, and routers within or surrounding the user’s Swift infrastructure (dedicated or shared) referred to generically as network devices protecting the secure zone or the customer client connectors.
- **Graphical user interface (GUI)**: software that produces the graphical interface for a messaging interface, a communication interface or a connector (for example, Alliance Web Platform Server-Embedded, Swift Microgateway Front-End, CREST WebGUI+, and equivalent products).
- **Alliance Connect Virtual on Premises VPN**: a new virtual (SSR) VPN instance to be deployed on the customer’s premises in dedicated virtual machines to connect to the Swift network, will become available as part of the Alliance Connect portfolio because of the evolution to a new technology between 2026 and 2028. This Alliance Connect Virtual on Premises VPN, which includes its hosting virtualisation platform, is explicitly identified as in scope of several controls. When ‘*Virtual VPN*’ is used in user’s environment drawings, the term refers to such new Alliance Connect Virtual on Premises VPN instance.
- **Operators**: Operators are individual end users and administrators that directly interact with the users’ Swift infrastructure at the application or OS level.
- **Operator PCs**: the end user’s or administrator’s computing device (typically a desktop or laptop) used to conduct their duties as an operator (to use, operate, or maintain the user’s Swift infrastructure residing on premises or externally hosted) or as a user (to use, for business transaction management, a remote Swift infrastructure or application operated by a service provider or Swift, or a combination, depending on the architecture type).

A **general-purpose operator PC** is generally located in the general enterprise IT environment and is used for daily business activities including accessing the user’s or a remote Swift infrastructure or an application operated by a Swift connectivity provider, a Group Hub, or an outsourcing agent, depending on the architecture type. It also includes devices (physical or virtual desktop, laptops but also other devices such as tablets or mobiles) managed by the customer and used to interact with the messaging or communication interface, a GUI, a connector, a transaction business control solution, or a Swift-related application exposed by a Swift connectivity provider, a Group Hub, or an outsourcing agent.

A **dedicated operator PC** is located in the secure zone and is dedicated to interact with components of the secure zone (sometimes also referred to as an *operational console*).

The term **operator PC** alone refers to both general-purpose and dedicated operator PCs.



- **Data exchange layer:** the transport of data between the Swift-related components (in the user's Swift infrastructure or at a service provider) and a user back-office first hop, at application level, as seen from the Swift-related components. This can be performed directly between the back-office first hop and the component in the secure zone or through **bridging servers** such as (one or a chain of) middleware servers, other systems supporting the technical transport, or file transfer servers.
- **Middleware server:** local middleware systems implementations, such as the IBM® MQ server (including MQ queues manager, MQ appliance, or both), Apache Kafka or Solace server/broker, or other systems used for data exchange between the Swift-related components (in the user's Swift infrastructure or at a service provider) and the user back-office first hop. Usually considered as a bridging server, it must however be considered as a customer connector when used to facilitate an external connection with Swift-related components shared by a service provider.
- **File transfer server:** solution, such as an sFTP server, used to exchange files between the Swift-related components (in the user's Swift infrastructure or at a service provider) and the user back-office first hop. Usually considered as a bridging server, it must however be considered as a customer connector when used to facilitate an external connection with Swift-related components shared by a service provider.
- **By default, all those components** and in particular the customer API connectors and the customer client connectors consuming APIs **fall in scope** of the security controls and definitely when they manage (create, submit, cancel, stop, recall or modify) business transactions or entitlements related to their management. Business transactions are basically the payment instructions (such as in Swift messaging MT 101, MT 103, MT 202, MT 205, their MX equivalent, pain.001, pacs.008, pacs.009 or any calls acting similarly) or instructions that lead to a payment. **It is possible to descope some components under the conditions** that they:
  - Do not have capabilities to manage or facilitate the transfer of business transactions and
  - Do not embed API or instructions requiring business signature and
  - Do not use credentials that have entitlement that can manage or transfer business transactions.

A complementary scope analysis supported by a risk assessment must confirm that those conditions are continuously met including when new API calls, functionalities or credentials are incorporated or added into the component. Consult also the [Knowledge Base article 5026358](#) for additional information.

**Note: Users must attest** for all in-scope components in their live, back-up, and disaster recovery environment, while **taking into account the** specific but still **comprehensive architecture, specifically declaring the most encompassing or all-embracing architecture type**; that architecture type can be identified using the [decision tree](#). To respond to extreme scenarios (such as ransomware or third-party component compromise) affecting the live, back-up, and disaster recovery environments, it might be required to set up an isolated light footprint environment. The definition, maintenance and activation, under some conditions, of such an isolated light footprint environment must be supported by a formal and up-to-date risk assessment covering the potential limited compliance due to the nature of this environment.

- Test systems are not considered in scope of the security controls as long as (i) they are fully separated from production or live environment (including separate HSMs) and (ii) they are configured to only support test traffic (for example, by only using lite certificates on test only logical terminals). If the test systems are not fully separated or can be configured for live traffic, then users must take the test systems in scope and make sure that the same security controls are applied as for production or live systems.
- Users should still implement good security hygiene on their test systems to also make sure they cannot be easily reconfigured for live traffic.
- Development systems must not be within the secure zone and are not connected to the Swift network and are therefore, not considered in scope.

B) The following **components** are **out of scope**:

- **User back office:** the systems responsible for business logic, (business) transaction generation, and other activities that occur before transmission into the user's Swift infrastructure. For example:
  - Back-office implementations such as SAP, General Ledger, or applications that use an MQ, Kafka or Solace kind of client to liaise with the user's Swift infrastructure are out of scope unless co-hosted<sup>4</sup> with a Swift-related in-scope component (component in the user's Swift infrastructure).
  - An application or system relying on a communication interface, such as Alliance Gateway (see Drawing 3b) or a Swift connector, such as Direct Link or Swift Microgateway (see Drawing 5) or, a customer connector (see Drawing 6b) for API calls to Swift remains a back-office system and is out of scope unless i) co-hosted with the communication interface or the connector or ii) using the specifications or integrating the Swift SDK to connect and transmit business transactions independently to Swift.

Although back-office systems responsible for transactions generation are typically outside of the CSP/CSCF scope, it is strongly recommended to protect them by implementing controls from a security framework (potentially using the CSCF principles) to minimise the risks into the broader end-to-end transaction chain.

- **General Enterprise IT environment:** the general IT infrastructure used to support the broader organisation (for example, general-purpose PCs, mail servers, or directory services, servers supporting IT processes such as the Change and Release Management for third-party and in-house developed components or Infrastructure as Code).

Although servers supporting the general enterprise IT environment are typically outside of the CSP/CSCF scope, it is strongly recommended to protect them by implementing controls from a security framework (potentially using the CSCF principles) to protect the secure zones and the components they contain.

- **Connections to the Swift network** supplied by Swift Network Partners and Internet connections to the Swift network are also out of scope. **However**, the remotely managed by Swift Alliance Connect (SRX) VPN boxes are in scope of control **3.1**; they are expected to be in an environment with appropriate physical controls. **Similarly**, the Alliance Connect (vSRX) Virtual VPN instances (hosting systems or machines), only available through the cloud providers approved as per the Swift Cloud Provider Programme, are also in scope of the controls **3.1** and **1.3** that are covered by those cloud providers as per the programme.

Swift plans to evolve its Alliance Connect portfolio to a new technology (Software-Defined Wide Area Network) as from 2026: new (SSR) VPN models (respectively Alliance Connect Hardware on Premises and Alliance Connect Virtual on Public Cloud) will progressively replace the current (SRX) VPN boxes and the (vSRX) Virtual VPN instances. They are in all aspects subject to the same controls 3.1 and 1.3 as the models they replace. In addition, a new virtual VPN option (Alliance Connect Virtual on Premises VPN), to be deployed by customers on their premises on a dedicated virtual machine, will also be available. That Alliance Connect Virtual on Premises VPN instance is in scope of several controls as per the above section A).

C) **Co-hosting components** and turning those components **in scope**:

The primary purpose of a secure zone is to contain and protect Swift-related systems. The secure zone can contain non-Swift related systems provided those non-Swift related systems are protected similarly to Swift-related systems. All components within the secure zone must be protected to an equivalent level of security and trust by applying controls applicable to the Swift-related components.

---

<sup>4</sup> Components deployed or running on a same physical system or virtual machine (created on a virtualisation or cloud platform). Note that containerised applications are considered, by default as co-hosted on the same physical system or virtual machine that hosts the container itself (see control 1.3 for more info).



Likewise, the purpose of a Swift-related system is to host or run a Swift-related component. In case other (non-Swift related) applications are co-hosted<sup>5</sup> with a Swift-related component (thus running on that Swift-related system), such applications are considered in scope similarly to the Swift-related component, irrespective on the underlying layer (individual/physical system, virtual machine on a virtualisation platform or in the cloud).

The virtualisation and cloud platform must also be specifically considered; deployment in the cloud is simply an abstraction of the virtualisation platform and a similar approach must be considered in line with the below section F) Outsourcing.

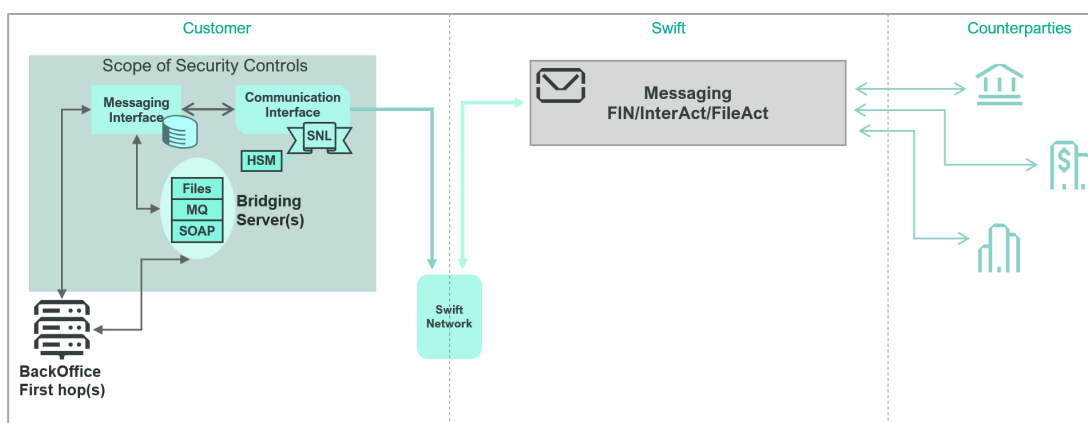
#### D) Sharing/reusing credentials of components in scope:

As a rule, ancillary or complementary services, allowing queries on preceding business transactions (for instance through the Basic Tracker), pre-validation, conversion or screening and performed before submitting actual business transactions, are considered as out of scope.

However, sharing/reusing credentials and roles/entitlements used for business transactions on systems or components for those ancillary services turns those systems or components in scope.

#### E) Drawings identifying various components to set the scope of the Security Controls

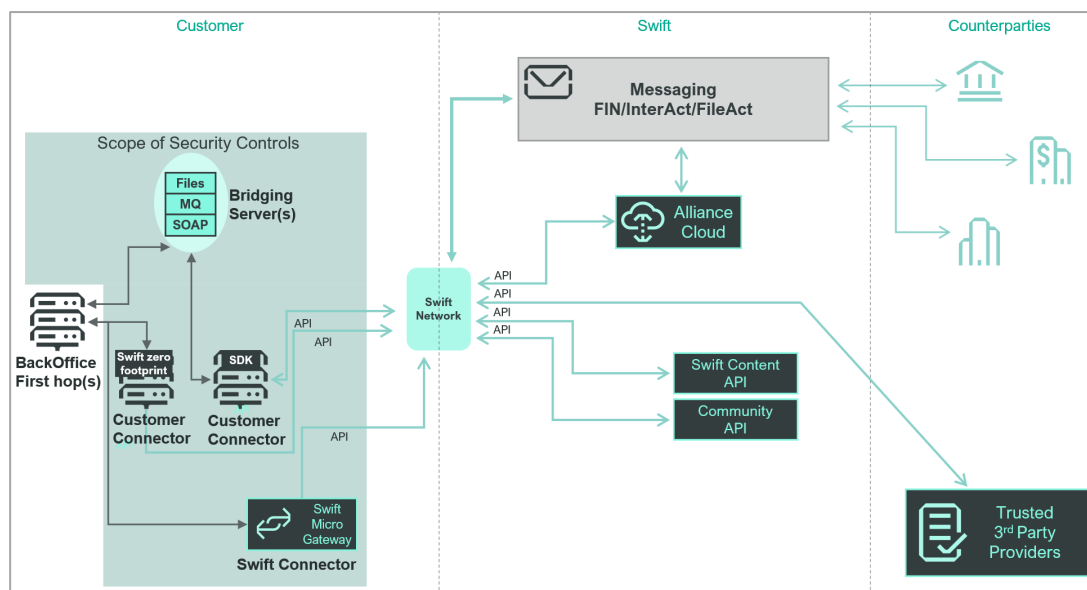
The below drawing presents a classical user's Swift infrastructure that contains a messaging, a communication interface with its linked SwiftNet Link and Swift Hardware Security Modules. The messaging interface exchanges data with various Back Office first hops either directly or through bridging servers.



**Drawing 2b: Scope of Security Controls – Classical infrastructure**

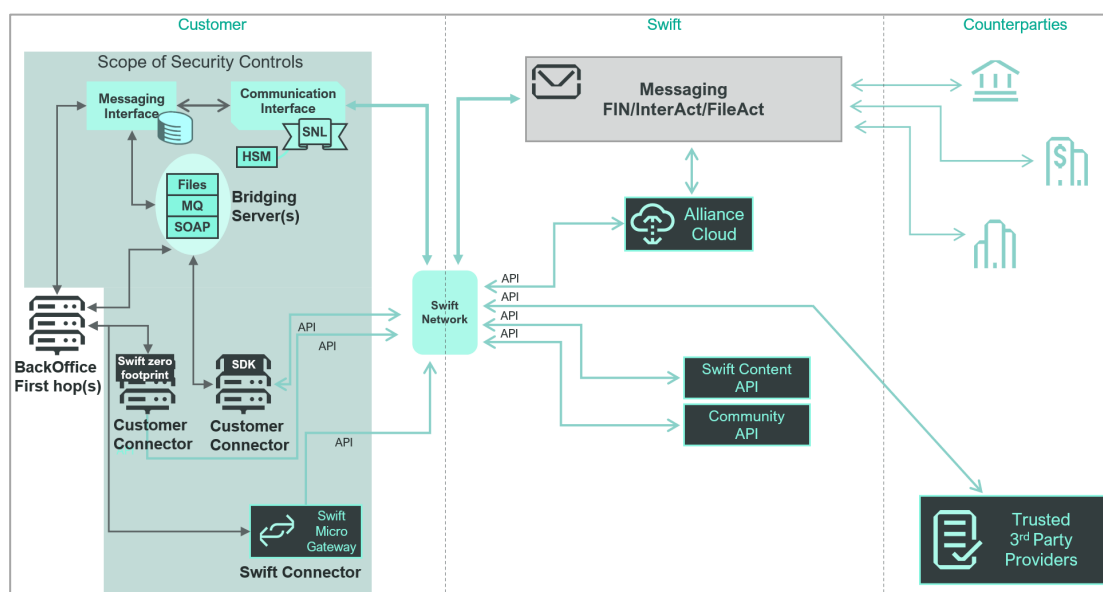
The Swift API channel introduced new components and ways to connect through the Swift Network and consume services as displayed in the following high level drawing. As the CSCF focus on the customers' infrastructure, more information regarding the Swift API channel can be found on [swift.com](https://swift.com).

<sup>5</sup> Components deployed or running on a same physical system or virtual machine (created on a virtualisation or cloud platform). Note that containerised applications are considered, by default as co-hosted on the same physical system or virtual machine that hosts the container itself (see control 1.3 for more info).



**Drawing 2c: Scope of Security Controls – API Channel**

There exists hybrid user's Swift infrastructure mixing classic components and API connectors that will all have to be protected in line with the CSCF controls. The below drawing illustrates an example of an hybrid infrastructure.



**Drawing 2d: Scope of Security Controls – Hybrid infrastructure**

**Appendix F** supports the identification of elements or Swift-related components in-scope.

## F) Outsourcing

Users that engage with third parties (as per the Glossary of Terms, an external IT provider, a cloud provider or an [outsourcing agent](#) which can be an external IT provider or a cloud provider) to host or operate in full or in part the user's own Swift infrastructure must be aware of the following:

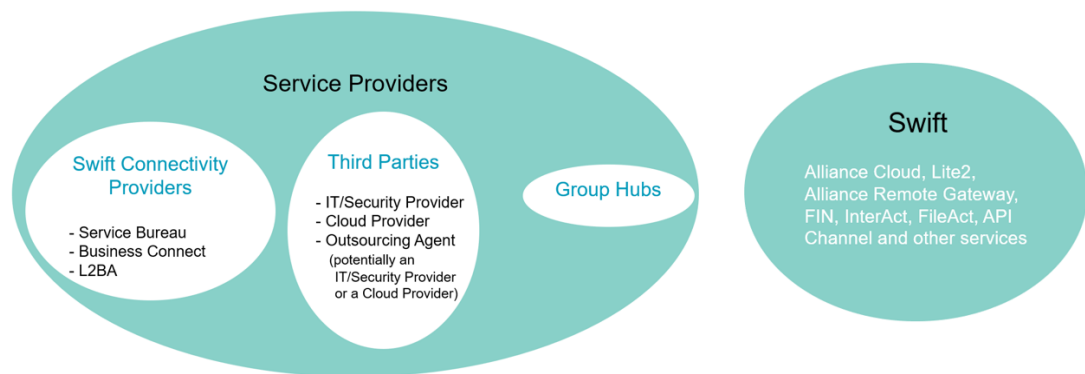
- Users are still responsible and accountable to attest for their own comprehensive architecture type (on premises and outsourced) as if it was operated on premises.
- Consequently, users must

- Consult the [Outsourcing Agents Security Requirements Baseline](#), which explains the expected security requirements for the various models
- Obtain reasonable comfort<sup>6</sup> from such third parties that the outsourced activities are protected, at a minimum, to the same standard of care as if operated within the originating organisation and in line with the CSCF security controls. Such third parties can rely on their compliance programme, that usually builds on maintained certification(s) or assurance (such as versus SOC 2 type 2, PCI-DSS or NIST) to map with the Outsourcing Agents Security Requirements Baseline when providing comfort to users they serve.

By default, Swift connectivity providers (as per the Glossary of Terms, a service bureau, a Business Connect or a Lite2 for Business Application provider) are not considered as outsourcing agents (the Swift connectivity providers are audited as per their respective provider programme). However, as per section 5.2 of the [Outsourcing Agents Security Requirements Baseline](#), when there is a specific contractual relationship with a Swift connectivity provider to host or operate some components a user owns, the Swift connectivity provider must be considered, for those components, as an outsourcing agent, consequently a third party, and the above applies.

**Appendix G** illustrates a typical spread of responsibilities to consider when outsourcing to a cloud provider and in particular through an Infrastructure as a Service (IaaS) model.

Below drawing visualises the services providers as they are defined in the CSCF (see the Glossary of Terms) where Swift is not considered as a service provider.



<sup>6</sup> See the Glossary of Terms for the definition

# Architecture Types

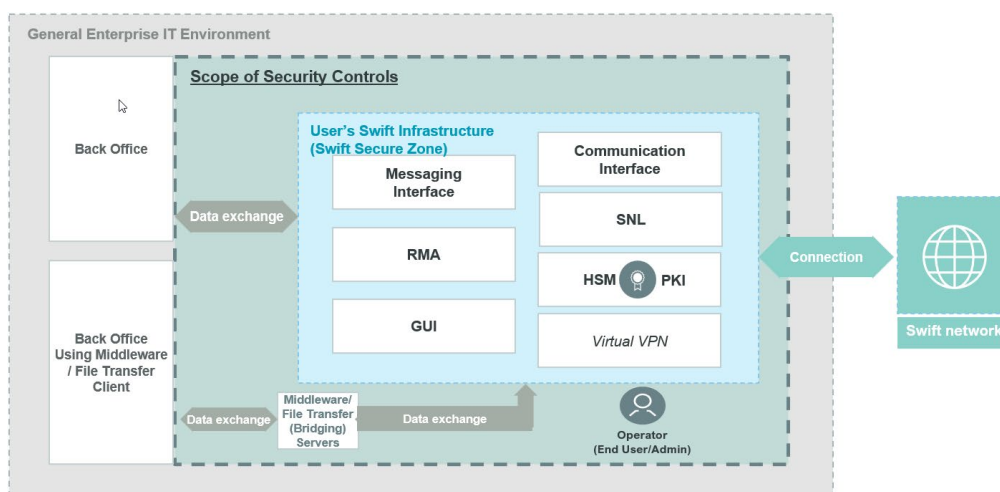
Each user must identify which of the five reference architecture types (Drawings 3-7) most closely matches their own architecture deployment to determine which components are in scope (a CSP architecture [decision tree](#) is available). Depending on the architecture type where the most comprehensive one has to be chosen, some security controls may or may not apply.

The five reference architectures are as follows, where component or licence ownership is the key differentiator:

- **Architecture A1** – Users owning the communication interface (and, generally, the messaging interface)

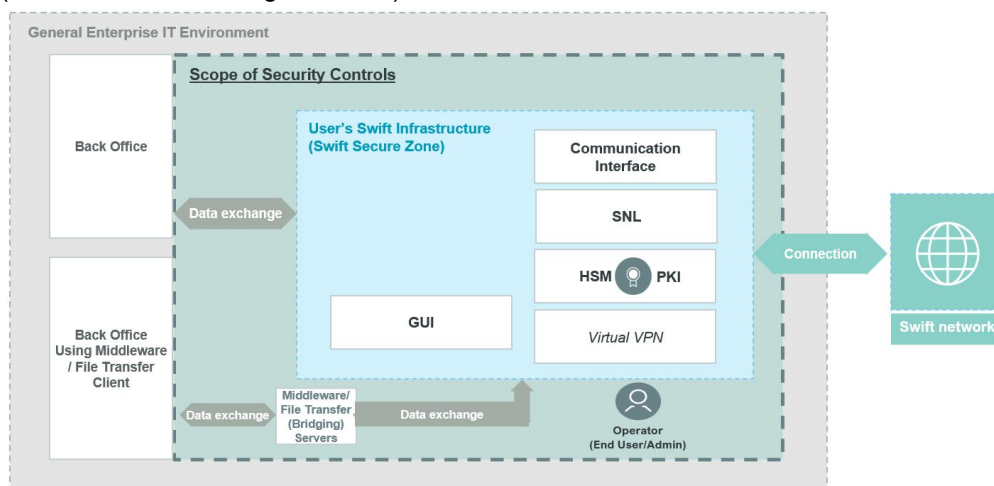
The communication interface is owned by the user.

Drawing 3a illustrates the case where both the messaging interface and the communication interface licences are owned by the user and reside within the environment.



**Drawing 3a: Architecture A1 – Interfaces within the user environment**

Users that do not own a messaging interface but only own a communication interface (such as in the Drawing 3b below) are also considered as **architecture A1**.



**Drawing 3b: Architecture A1 – Communication interface only within the user environment**

The **architecture A1** type also includes hosted solutions where the user owns the licence for the communication interface that the user operates on behalf of other users, or the communication interface owned by the user is operated for personal use by a third party within (or hosted) outside the user environment. An Alliance Gateway Instant

linked with a back-office system without any messaging interface illustrates such set-up.

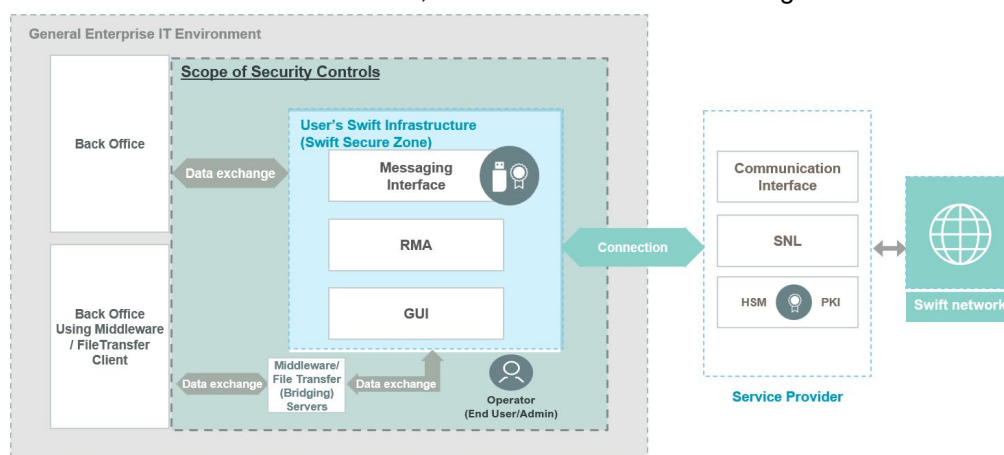
Although back-office systems responsible for transactions generation are typically outside of the CSP/CSCF scope, it is strongly recommended to protect them by implementing controls from security framework(s) (potentially using the CSCF principles) to minimise the risks into the broader end-to-end transaction chain.

When additional middleware or file transfer servers secure the data exchange with the back-office first hop, users must also consider the controls applicable to bridging servers.

- **Architecture A2** – Users owning the messaging interface, but not the communication interface

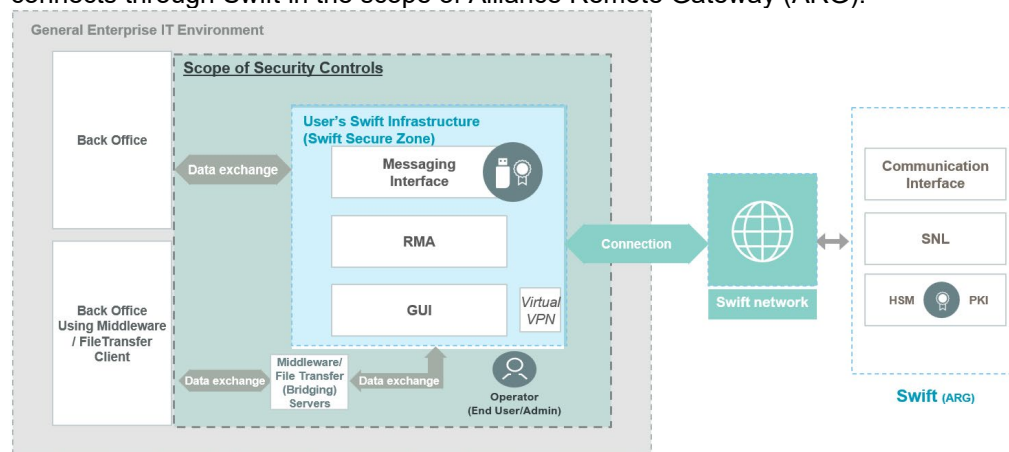
The messaging interface is owned, but a Swift connectivity provider (for example, a service bureau), a Group Hub or Swift<sup>7</sup> owns the licence for the communication interface.

Drawing 4a illustrates the case where the messaging interface is owned by the user, resides within the user environment, which connects to Swift through a service bureau.



**Drawing 4a: Architecture A2 – Messaging Interface only within the user environment and connecting through a Service Provider such as a service bureau**

Drawing 4b illustrates the case where the messaging interface, owned by the user, connects through Swift in the scope of Alliance Remote Gateway (ARG).



**Drawing 4b: Architecture A2 – Messaging Interface only and users connects through Swift Alliance Remote Gateway**

This architecture type also includes hosted solutions where the user has the licence for the messaging interface that is hosted or operated on the user's behalf by a third party

<sup>7</sup> In the scope of Alliance Remote Gateway

or a Swift connectivity provider (that in this case must be considered as an outsourcing agent).

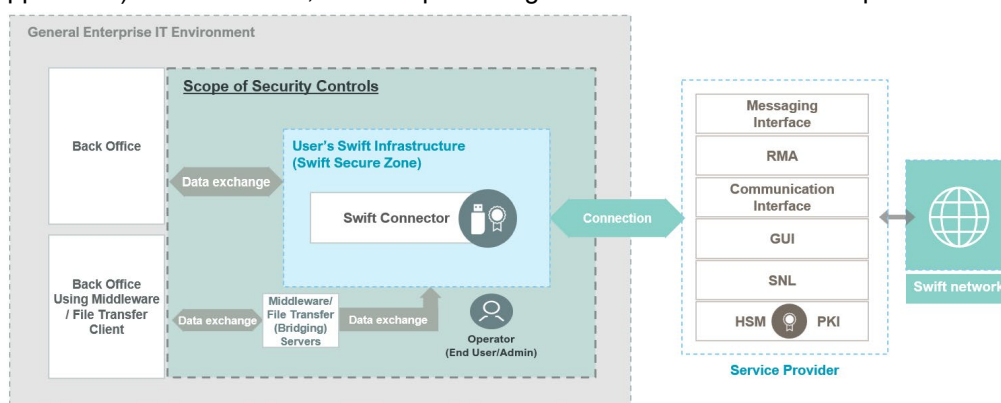
Although back-office systems responsible for transactions generation are typically outside of the CSP/CSCF scope, it is strongly recommended to protect them by implementing controls from security framework(s) (potentially using the CSCF principles) to minimise the risks into the broader end-to-end transaction chain.

When additional middleware or file transfer servers secure the data exchange with the back-office first hop, users must also consider the controls applicable to bridging servers.

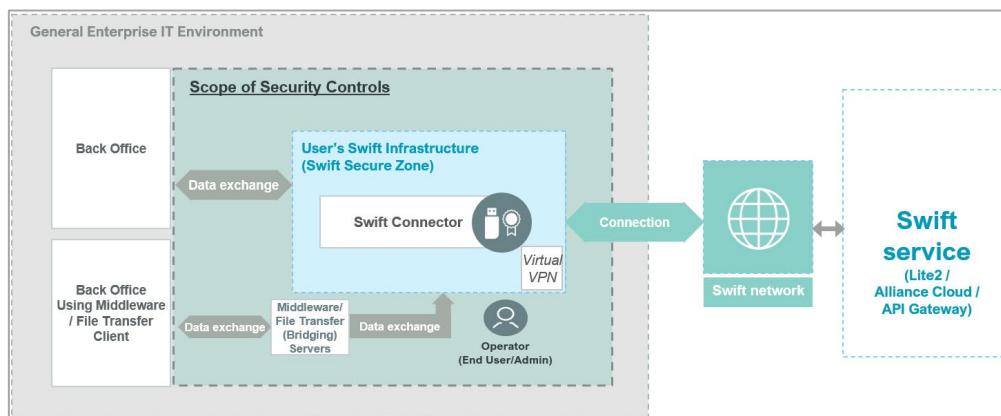
- **Architecture A3 – Swift Connector**

A Swift connector<sup>8</sup> is used (such as in Drawing 5a and 5b) within the user environment to facilitate an application-to-application communication with an interface at a Swift connectivity provider, at a remote Group Hub or with Swift services (such as Alliance Cloud or Alliance Lite2) with no (messaging or communication) interface.

Optionally, this set-up can be used in combination with a GUI solution (user-to-application). In such cases, controls pertaining to the GUI must also be implemented.



**Drawing 5a: Architecture A3 – Swift Connector towards a Swift connectivity provider**



**Drawing 5b: Architecture A3 – Swift Connector towards a Swift service**

This architecture type also includes hosted solutions of the user's Swift connector that is hosted or operated on the user's behalf by a third party or a Swift connectivity provider (that in this case must be considered as an outsourcing agent).

Although back-office systems responsible for transactions generation are typically outside of the CSP/CSCF scope, it is strongly recommended to protect them by implementing controls from security framework(s) (potentially using the CSCF principles) to minimise the risks into the broader end-to-end transaction chain.

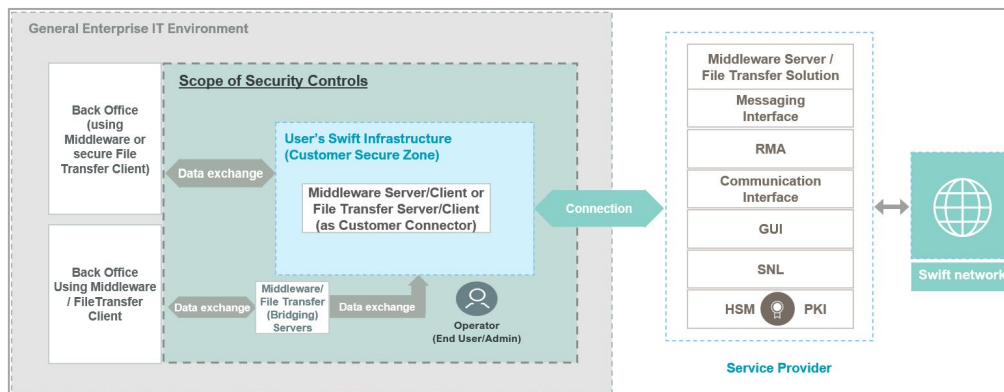
<sup>8</sup> For example, Alliance Cloud SIL, Direct Link, Alliance Lite2 AutoClient, in combination with SIL or not, or Swift Microgateway



When additional middleware or file transfer servers secure the data exchange with the back-office first hop, users must also consider the controls applicable to bridging servers.

- **Architecture A4 – Customer Connector**

When a user does not have any Swift footprint but uses, within its environment<sup>9</sup>, a system running a software application (for example, a file transfer solution or a middleware server or client that is a customer connector, see Drawing 6a) to facilitate an application-to-application external connection with an interface, a shared Swift-related application or solution at a Swift connectivity provider or at a remote Group Hub.



**Drawing 6a: Architecture A4 – Middleware/File Transfer Server/Client as Connector**

This architecture type also includes hosted solutions of the user's customer (client) connector that is hosted or operated on its behalf by a third party or by a Swift connectivity provider (that in this case must be considered as an outsourcing agent).

Although back-office systems responsible for transactions generation are typically outside of the CSP/CSCF scope, it is strongly recommended to protect them by implementing controls from security framework(s) (potentially using the CSCF principles) to minimise the risks into the broader end-to-end transaction chain.

This architecture type also includes the use, as a customer connector, of a file transfer solution (client or server) or a middleware client or server, or a combination, to connect with i) an outsourcing agent shared components or ii) a remote Group Hub through externally exposed connections (that means, not through a wide area network - WAN or extended virtual local area network - VLAN), without any Swift connector. See the [Knowledge Base article 6000598](#) for additional information.

When additional middleware or file transfer servers secure the data exchange with the back-office first hop, users must also consider the controls applicable to bridging servers.

**Architecture A4** also includes, when there is no Swift footprint, customer (client) connectors that are applications used within the user environment<sup>10</sup> that implement:

- Swift APIs to directly connect and independently transmit<sup>11</sup> business transactions to Swift services (a future messaging service<sup>12</sup> or the Transaction Manager exposed by Swift) or manage those business transactions. The implementation of the Swift APIs (basically by either using the specifications or integrating the Swift

<sup>9</sup> On premises or externally hosted, in the cloud or not.

<sup>10</sup> On premises or externally hosted, in the Cloud or not.

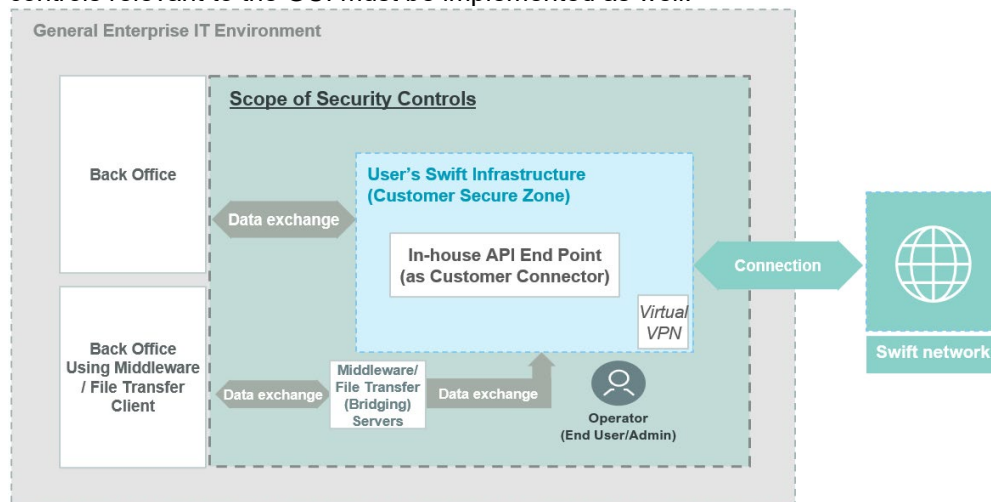
<sup>11</sup> Without the use of a communication interface or a dedicated Swift (API) Connector.

<sup>12</sup> Business transactions to messaging services refers to requests introducing or affecting payments (such as creation of MT 101, MT 103, MT 202, MT 205, their MX equivalent, pain.001, pacs.008 and pacs.009, or cancelling/stopping/recalling/modifying those requests) or instructions that lead to a payment. On the other side, queries on previous transactions (such as through the Basic Tracker), pre-validation, conversion or screening performed before submitting business transactions are not considered affecting messaging services. See the last bullet of the section A) of Scope of Security Controls.

SDK) renders such application a custom-made API endpoint referred to as a customer connector or a non-Swift footprint (see Drawing 6b).

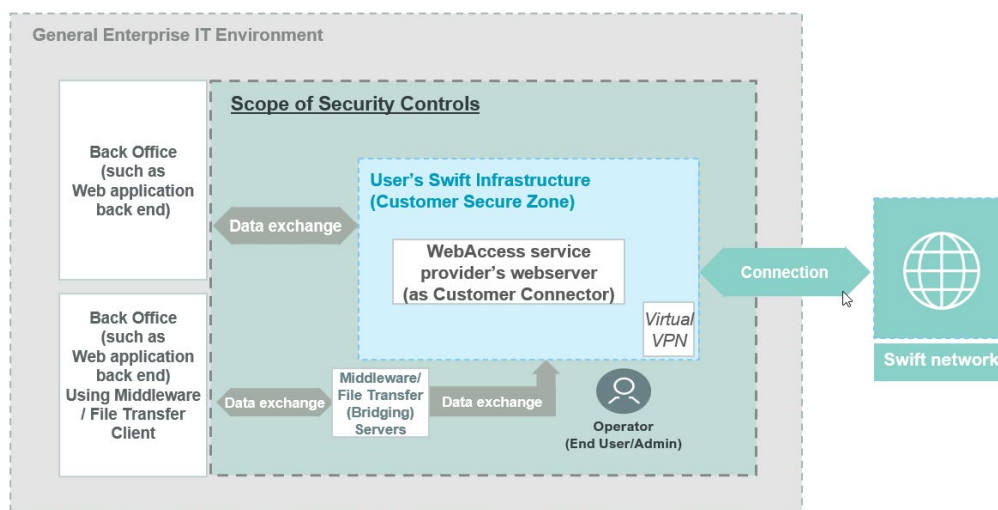
- Service provider APIs or other means to externally connect and transmit business transactions to a service provider shared service (potentially a Swift connectivity provider) which in turn will liaise, directly or not, with Swift.

This last set-up could also integrate a GUI solution (user-to-application). In such case, controls relevant to the GUI must be implemented as well.



**Drawing 6b: Architecture A4 – Customer (in-house API) Connector**

This architecture type also includes hosted solutions of the user's customer (client) connector that is hosted or operated on its behalf by a third party or a Swift connectivity provider (that in this case must be considered as an outsourcing agent).



**Drawing 6c: Architecture A4 – WebAccess service provider webserver front-end**

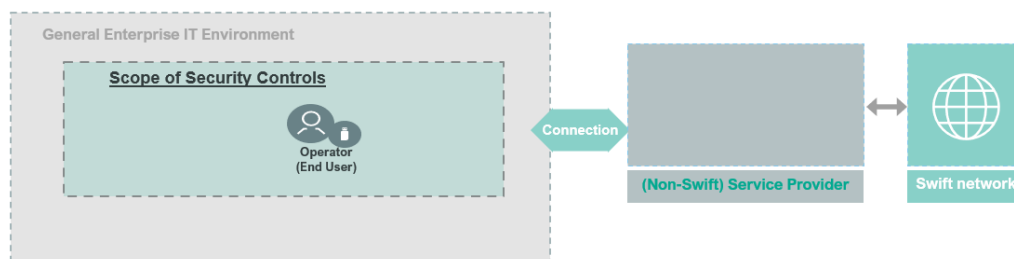
This architecture type also includes, when there is not Swift footprint, the webserver front-end, as customer connector, a Swift WebAccess service provider relies on to offer its web application over Swift. In a distinct 2- or 3-tier model, the web application or back end is considered as a back-office system, as illustrated above.

Although back-office systems responsible for transactions generation are typically outside of the CSP/CSCF scope, it is strongly recommended to protect them by implementing controls from security framework(s) (potentially using the CSCF principles) to minimise the risks into the broader end-to-end transaction chain.

- **Architecture B – No local user footprint in scope**

No Swift-specific infrastructure component is used within the user environment. The following two types of set-ups are covered by this architecture type:

- Users only access Swift messaging services through a GUI application at the service provider or at Swift (user-to-application). The PC or device used by those users to submit or affect business transactions must be considered as a general-purpose operator PC and must be protected accordingly.
- A user's Swift infrastructure that, while using a customer connector, has formally no component in scope as per [the last bullet above the note at the end of section A\)](#) of the section Scope of Security Controls.



**Drawing 7a: Architecture B – No user footprint connecting to a Service Provider (other than Swift)**



**Drawing 7b: Architecture B – Interactive User connecting to Swift**

Although back-office systems responsible for transactions generation are typically outside of the CSP/CSCF scope, it is strongly recommended to protect them by implementing controls from security framework(s) (potentially using the CSCF principles) to minimise the risks into the broader end-to-end transaction chain.

This architecture type also includes users that only access Swift messaging services (user-to-application) with a browser, exposed by Alliance Cloud and Alliance Lite2. PCs used by those users to submit or affect business transactions must be considered as general-purpose operator PCs and must be protected accordingly.

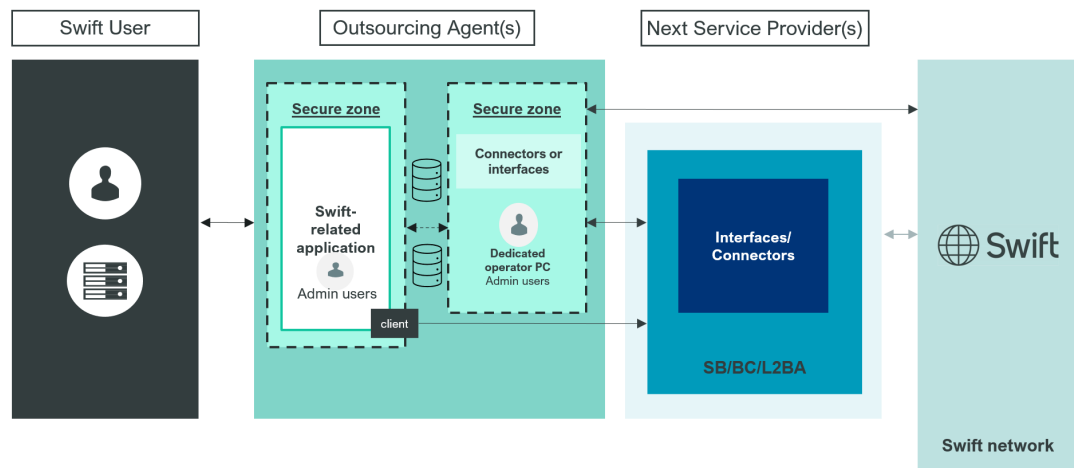
The security controls applicable for Architectures A1, A2, and A3 are identical<sup>13</sup> and fewer controls apply to Architecture A4. These architectures are referenced collectively on the following pages as type A. Fewer security controls apply to users that utilise Architecture type B (for more information, see the Security Controls Summary Table section).

### Outsourcing agent reliance

In addition to the user's infrastructure that is, in full or in part, hosted or operated on its behalf by a third party, there are other cases where an outsourcing agent offers applications that connect to Swift through, for instance, a service bureau (SB), a Business Connect (BC) or a Lite2 Business Application (L2BA) provider as per below drawing. In this case, the user

<sup>13</sup> Except for Control 6.3 Database Integrity that explicitly does not apply to any architecture A3

has to seek the architecture type (usually A4 or B) and compliance results from the outsourcing agent in order to fill its own attestation. More information is available on the [Knowledge Centre \(swift.com\)](https://www.swift.com/knowledge-centre).



**Drawing 8: Outsourcing agent connecting a user to Swift through a Swift connectivity provider**

# Security Controls Structure

Each security control in this document is structured into the following three parts:

- general control information
- control definition
- implementation guidance

## General Control Information

- **Control Number and Title:** Each control has a unique number and title. If the control number is suffixed with an *A*, then this indicates that the control is *Advisory*.
- **Control Type:** This identifies the control as *Mandatory* or *Advisory*. Users must implement all applicable Mandatory controls, taking into account the architecture type. Advisory controls are considered as a security best practice and are strongly recommended for additional implementation.
- **Applicability to Architecture types:** Controls are applicable either to users with **Architecture types A1, A2, A3, A4, type B**, or a combination of types. As such, users with **Architecture type B** are not required to comply with controls applicable to **Architecture types A1, A2, A3 and A4** only.

## Control Definition

- **Control Objective:** The security goal to be achieved, irrespective of the implementation method.
- **In-scope Components:** The specific Swift-related components covered by this particular control. (For more information, see [Scope of Security Controls](#). The [Controls Matrix](#) document can also be consulted to have a view of the relevant controls per in-scope component.)  
**Note:** When extending the scope to new components, the new in-scope components can initially be tagged as *Advisory*<sup>14</sup>.
- **Risk Drivers:** The specific risks addressed by this particular control. A full matrix of risks is documented in [Appendix A](#).

## Implementation Guidance

- **Control Statement:** The suggested means by which the Control Objective can be fulfilled.
- **Control Context:** Additional introductory background information about this control.
- **Implementation Guidelines:** The Swift-formulated method for control implementation.

---

**Important** Users must attest against their compliance with all mandatory control objectives. Additional details about implementation options for compliance are described in the next section. Users can also find additional valuable information in the [CSP FAQ](#) (Knowledge Base article 5021823) and the [Security Guidance Document](#) (log in on swift.com required).

---

---

<sup>14</sup> The Change Management process makes sure that the Swift community has sufficient time to understand and implement any future changes to the control requirements. Typically, new mandatory controls will be first introduced as advisory, thereby giving all users at least two cycles to plan, budget and implement.

# Security Controls Compliance

As per the above-described security controls structure, the objective of a control states the security goal to be achieved irrespective of the implementation method used.

To comply with a CSP security control, users must implement a solution that meets the control definition; namely, the solution:

- meets the stated control objective
- covers the documented in-scope components relevant for the user's architecture
- addresses the risk drivers (see [Appendix A](#) for a risk matrix and [Appendix C](#) for illustrations of such risks).

The *Control Statement* is the suggested means to fulfil the control objective and the *Implementation Guidelines* are common methods for implementing the control.

Compliance can be obtained by either of the following methods:

- A) Implement a solution aligned with the implementation guidance provided in this document.

The *implementation guidance* section should not be considered as a strict audit checklist because each user's implementation can vary. Therefore, in the case that some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be taken into account to properly assess the overall guideline's adherence level.

- B) Implement an alternative solution to the Swift-formulated implementation guidance, which equally meets the control definition.

In such a case, deployed controls, their effectiveness, and particular environment specificities must be taken into account to properly assess the control definition compliance of the solution (risk assessment approach).

Both methods are considered as valid and equally robust from a risk perspective.

Users are ultimately responsible for assessing the suitability of Swift-formulated implementation guidance in their environment or determining if they want to adopt alternative implementation solutions.

It is the expectation that only a small subset of users (typically those with a high level of Information Security Risk Management maturity within their organisation) will consider alternative implementation methods for one or more controls to cope with large or complex configurations.

Reliance on recent certification, audit, other relevant (business) assessment, or regulator answers to confirm effectiveness of the control is allowed for any CSP control as per the Independent Assessment Framework (IAF).



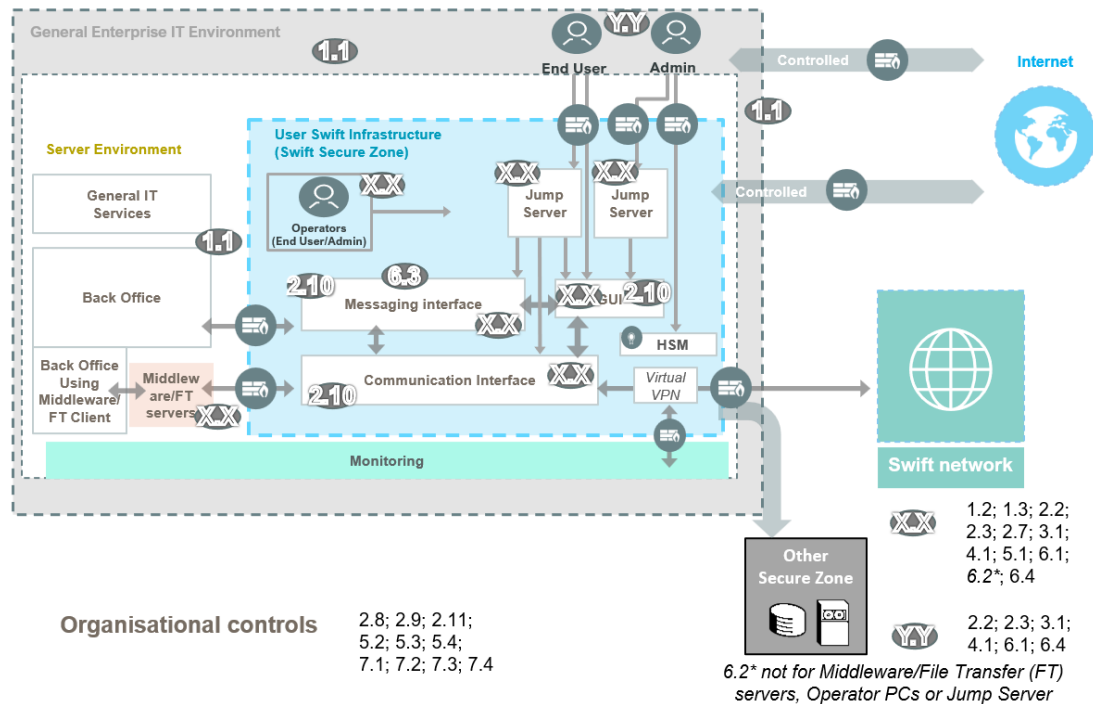
# Security Controls Summary Table

The following table provides an overview of all mandatory and advisory security controls, structured according to the principle they support and with reference to the architecture type to which they relate. In addition, the table identifies the relevance of the controls, depending on the architecture type. Advisory controls are notated with an *A* after the control number (for example, 2.5A) throughout this document, and are shaded in the table below. Likewise, individual shaded cells in the table below are advisory for some specific architecture types even when the control is mandatory for other architecture types.

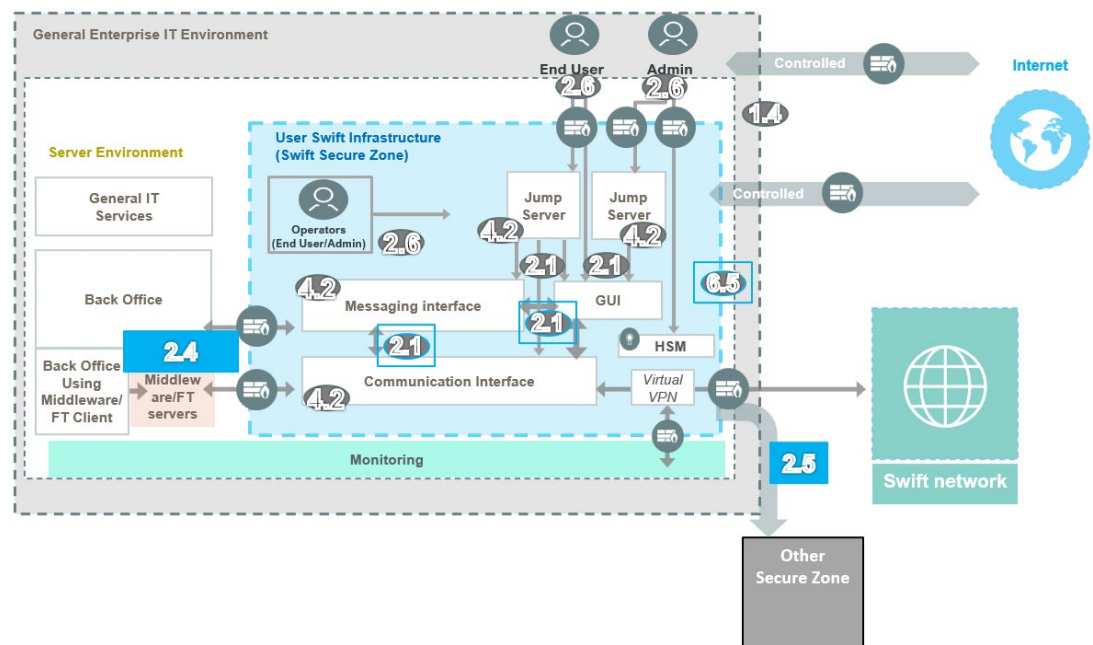
| Mandatory and Advisory Security Controls                                                   | Architecture Type |    |    |    |   |
|--------------------------------------------------------------------------------------------|-------------------|----|----|----|---|
|                                                                                            | A1                | A2 | A3 | A4 | B |
| <b>1 Restrict Internet Access and Protect Critical Systems from General IT Environment</b> |                   |    |    |    |   |
| 1.1 Swift Environment Protection                                                           | •                 | •  | •  |    |   |
| 1.2 Operating System Privileged Account Control                                            | •                 | •  | •  | •  | • |
| 1.3 Virtualisation or Cloud Platform Protection                                            | •                 | •  | •  | •  | • |
| 1.4 Restriction of Internet Access                                                         | •                 | •  | •  | •  | • |
| 1.5 Customer Environment Protection                                                        |                   |    |    | •  |   |
| <b>2 Reduce Attack Surface and Vulnerabilities</b>                                         |                   |    |    |    |   |
| 2.1 Internal Data Flow Security                                                            | •                 | •  | •  |    |   |
| 2.2 Security Updates                                                                       | •                 | •  | •  | •  | • |
| 2.3 System Hardening                                                                       | •                 | •  | •  | •  | • |
| 2.4 Back Office Data Flow Security                                                         | •                 | •  | •  | •  |   |
| 2.5A External Transmission Data Protection                                                 | •                 | •  | •  | •  |   |
| 2.6 Operator Session Confidentiality and Integrity                                         | •                 | •  | •  | •  | • |
| 2.7 Vulnerability Scanning                                                                 | •                 | •  | •  | •  | • |
| 2.8 Outsourced Critical Activity Protection                                                | •                 | •  | •  | •  | • |
| 2.9 Transaction Business Controls                                                          | •                 | •  | •  | •  | • |
| 2.10 Application Hardening                                                                 | •                 | •  | •  |    |   |
| 2.11A RMA Business Controls                                                                | •                 | •  | •  | •  | • |
| <b>3 Physically Secure the Environment</b>                                                 |                   |    |    |    |   |
| 3.1 Physical Security                                                                      | •                 | •  | •  | •  | • |
| <b>4 Prevent Compromise of Credentials</b>                                                 |                   |    |    |    |   |
| 4.1 Password Policy                                                                        | •                 | •  | •  | •  | • |
| 4.2 Multi-Factor Authentication                                                            | •                 | •  | •  | •  | • |
| <b>5 Manage Identities and Separate Privileges</b>                                         |                   |    |    |    |   |
| 5.1 Logical Access Control                                                                 | •                 | •  | •  | •  | • |
| 5.2 Token Management                                                                       | •                 | •  | •  | •  | • |
| 5.3A Staff Screening Process                                                               | •                 | •  | •  | •  | • |
| 5.4 Password Repository Protection                                                         | •                 | •  | •  | •  | • |
| <b>6 Detect Anomalous Activity to Systems or Transaction Records</b>                       |                   |    |    |    |   |
| 6.1 Malware Protection                                                                     | •                 | •  | •  | •  | • |
| 6.2 Software Integrity                                                                     | •                 | •  | •  | •  |   |
| 6.3 Database Integrity                                                                     | •                 | •  |    | •  |   |
| 6.4 Logging and Monitoring                                                                 | •                 | •  | •  | •  | • |
| 6.5A Intrusion Detection                                                                   | •                 | •  | •  | •  |   |
| <b>7 Plan for Incident Response and Information Sharing</b>                                |                   |    |    |    |   |
| 7.1 Cyber Incident Response Planning                                                       | •                 | •  | •  | •  | • |
| 7.2 Security Training and Awareness                                                        | •                 | •  | •  | •  | • |
| 7.3A Penetration Testing                                                                   | •                 | •  | •  | •  | • |
| 7.4A Scenario-based Risk Assessment                                                        | •                 | •  | •  | •  | • |

The following two drawings present visually where the controls would apply, using, for reference, one of many ways an **Architecture A1** could be designed. (See *Appendix B* for other reference architectures. The [Controls Matrix](#) document can also be consulted to have a view of the relevant controls per in-scope component.)

Drawing 9 shows the controls applicable at the infrastructure and systems levels and with organisational controls surrounding such environment. Drawing 10 focus on interactive and application flow controls between the Swift-related components and the operator PCs or back-office systems.



**Drawing 9: Infrastructure static and organisational controls**



**Drawing 10: Human/Application to Machine/application flow controls**